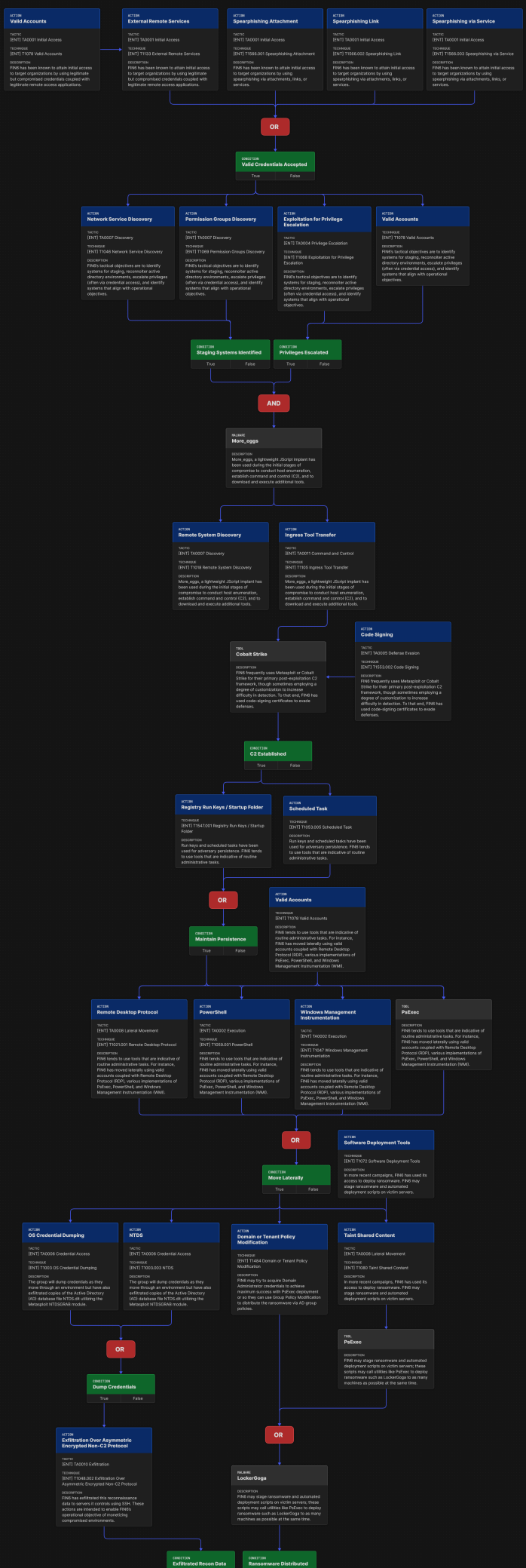
THREAT_ACTOR
DESCRIPTION
FIN6 is thought to be a financially motivated cyber-crime group. The group has aggressively targeted and compromised high-volume POS systems in the hospitality and retail sectors since at least 2015. FIN6 has targeted e-commerce sites and multinational organizations. Most of the group's targets have been located in the United States and Europe, but include companies in Australia, Canada, Spain, India, Kazakhstan, Serbia, and China.
ACTION
Valid Accounts
TACTIC
[ENT] TA0001 Initial Access
TECHNIQUE
[ENT] T1078 Valid Accounts
DESCRIPTION
FIN6 has been known to attain initial access to target organizations by using legitimate but compromised credentials coupled with legitimate remote access applications.
ACTION
External Remote Services
TACTIC
[ENT] TA0001 Initial Access
TECHNIQUE
[ENT] T1133 External Remote Services
DESCRIPTION
FIN6 has been known to attain initial access to target organizations by using legitimate but compromised credentials coupled with legitimate remote access applications.
ACTION
Spearphishing Attachment
TACTIC
[ENT] TA0001 Initial Access
TECHNIQUE
[ENT] T1566.001 Spearphishing Attachment
DESCRIPTION
FIN6 has been known to attain initial access to target organizations by using spearphishing via attachments, links, or services.
ACTION
Spearphishing Link
TACTIC
[ENT] TA0001 Initial Access
TECHNIQUE
[ENT] T1566.002 Spearphishing Link
DESCRIPTION
FIN6 has been known to attain initial access to target organizations by using spearphishing via attachments, links, or services.
ACTION
Spearphishing via Service
TACTIC
[ENT] TA0001 Initial Access
TECHNIQUE
[ENT] T1566.003 Spearphishing via Service
DESCRIPTION
FIN6 has been known to attain initial access to target organizations by using spearphishing via attachments, links, or services.
OR
CONDITION
Valid Credentials Accepted
True
False
ACTION
Network Service Discovery
TACTIC
[ENT] TA0007 Discovery
TECHNIQUE
[ENT] T1046 Network Service Discovery
DESCRIPTION
FIN6's tactical objectives are to identify systems for staging, reconnoiter active directory environments, escalate privileges (often via credential access), and identify systems that align with operational objectives.
ACTION
Permission Groups Discovery
TACTIC
[ENT] TA0007 Discovery
TECHNIQUE
[ENT] T1069 Permission Groups Discovery
DESCRIPTION
FIN6's tactical objectives are to identify systems for staging, reconnoiter active directory environments, escalate privileges (often via credential access), and identify systems that align with operational objectives.
ACTION
Exploitation for Privilege Escalation
TACTIC
[ENT] TA0004 Privilege Escalation
TECHNIQUE
[ENT] T1068 Exploitation for Privilege Escalation
DESCRIPTION
FIN6's tactical objectives are to identify systems for staging, reconnoiter active directory environments, escalate privileges (often via credential access), and identify systems that align with operational objectives.
ACTION
Valid Accounts
TECHNIQUE
[ENT] T1078 Valid Accounts
DESCRIPTION
FIN6's tactical objectives are to identify systems for staging, reconnoiter active directory environments, escalate privileges (often via credential access), and identify systems that align with operational objectives.
CONDITION
Staging Systems Identified
True
False
CONDITION
Privileges Escalated
True
False
AND
MALWARE
More_eggs
DESCRIPTION
More_eggs, a lightweight JScript implant has been used during the initial stages of compromise to conduct host enumeration, establish command and control (C2), and to download and execute additional tools.
ACTION
Remote System Discovery
TACTIC
[ENT] TA0007 Discovery
TECHNIQUE
[ENT] T1018 Remote System Discovery
DESCRIPTION
More_eggs, a lightweight JScript implant has been used during the initial stages of compromise to conduct host enumeration, establish command and control (C2), and to download and execute additional tools.
ACTION
Ingress Tool Transfer
TACTIC
[ENT] TA0011 Command and Control
TECHNIQUE
[ENT] T1105 Ingress Tool Transfer
DESCRIPTION
More_eggs, a lightweight JScript implant has been used during the initial stages of compromise to conduct host enumeration, establish command and control (C2), and to download and execute additional tools.
ACTION
Code Signing
TACTIC
[ENT] TA0005 Defense Evasion
TECHNIQUE
[ENT] T1553.002 Code Signing
DESCRIPTION
FIN6 frequently uses Metasploit or Cobalt Strike for their primary post-exploitation C2 framework, though sometimes employing a degree of customization to increase difficulty in detection. To that end, FIN6 has used code-signing certificates to evade defenses.
TOOL
Cobalt Strike
DESCRIPTION
FIN6 frequently uses Metasploit or Cobalt Strike for their primary post-exploitation C2 framework, though sometimes employing a degree of customization to increase difficulty in detection. To that end, FIN6 has used code-signing certificates to evade defenses.
CONDITION
C2 Established
True
False
ACTION
Registry Run Keys / Startup Folder
TECHNIQUE
[ENT] T1547.001 Registry Run Keys / Startup Folder
DESCRIPTION
Run keys and scheduled tasks have been used for adversary persistence. FIN6 tends to use tools that are indicative of routine administrative tasks.
ACTION
Scheduled Task
TECHNIQUE
[ENT] T1053.005 Scheduled Task
DESCRIPTION
Run keys and scheduled tasks have been used for adversary persistence. FIN6 tends to use tools that are indicative of routine administrative tasks.
OR
CONDITION
Maintain Persistence
True
False
ACTION
Valid Accounts
TECHNIQUE
[ENT] T1078 Valid Accounts
DESCRIPTION
FIN6 tends to use tools that are indicative of routine administrative tasks. For instance, FIN6 has moved laterally using valid accounts coupled with Remote Desktop Protocol (RDP), various implementations of PsExec, PowerShell, and Windows Management Instrumentation (WMI).
ACTION
Remote Desktop Protocol
TACTIC
[ENT] TA0008 Lateral Movement
TECHNIQUE
[ENT] T1021.001 Remote Desktop Protocol
DESCRIPTION
FIN6 tends to use tools that are indicative of routine administrative tasks. For instance, FIN6 has moved laterally using valid accounts coupled with Remote Desktop Protocol (RDP), various implementations of PsExec, PowerShell, and Windows Management Instrumentation (WMI).
ACTION
PowerShell
TACTIC
[ENT] TA0002 Execution
TECHNIQUE
[ENT] T1059.001 PowerShell
DESCRIPTION
FIN6 tends to use tools that are indicative of routine administrative tasks. For instance, FIN6 has moved laterally using valid accounts coupled with Remote Desktop Protocol (RDP), various implementations of PsExec, PowerShell, and Windows Management Instrumentation (WMI).
ACTION
Windows Management Instrumentation
TACTIC
[ENT] TA0002 Execution
TECHNIQUE
[ENT] T1047 Windows Management Instrumentation
DESCRIPTION
FIN6 tends to use tools that are indicative of routine administrative tasks. For instance, FIN6 has moved laterally using valid accounts coupled with Remote Desktop Protocol (RDP), various implementations of PsExec, PowerShell, and Windows Management Instrumentation (WMI).
TOOL
PsExec
DESCRIPTION
FIN6 tends to use tools that are indicative of routine administrative tasks. For instance, FIN6 has moved laterally using valid accounts coupled with Remote Desktop Protocol (RDP), various implementations of PsExec, PowerShell, and Windows Management Instrumentation (WMI).
OR
CONDITION
Move Laterally
True
False
ACTION
Software Deployment Tools
TECHNIQUE
[ENT] T1072 Software Deployment Tools
DESCRIPTION
In more recent campaigns, FIN6 has used its access to deploy ransomware. FIN6 may stage ransomware and automated deployment scripts on victim servers.
ACTION
OS Credential Dumping
TACTIC
[ENT] TA0006 Credential Access
TECHNIQUE
[ENT] T1003 OS Credential Dumping
DESCRIPTION
The group will dump credentials as they move through an environment but have also exfiltrated copies of the Active Directory (AD) database file NTDS.dit utilizing the Metasploit NTDSGRAB module.
ACTION
NTDS
TACTIC
[ENT] TA0006 Credential Access
TECHNIQUE
[ENT] T1003.003 NTDS
DESCRIPTION
The group will dump credentials as they move through an environment but have also exfiltrated copies of the Active Directory (AD) database file NTDS.dit utilizing the Metasploit NTDSGRAB module.
ACTION
Domain or Tenant Policy Modification
TECHNIQUE
[ENT] T1484 Domain or Tenant Policy Modification
DESCRIPTION
FIN6 may try to acquire Domain Administrator credentials to achieve maximum success with PsExec deployment or so they can use Group Policy Modification to distribute the ransomware via AD group policies.
ACTION
Taint Shared Content
TACTIC
[ENT] TA0008 Lateral Movement
TECHNIQUE
[ENT] T1080 Taint Shared Content
DESCRIPTION
In more recent campaigns, FIN6 has used its access to deploy ransomware. FIN6 may stage ransomware and automated deployment scripts on victim servers.
OR
CONDITION
Dump Credentials
True
False
TOOL
PsExec
DESCRIPTION
FIN6 may stage ransomware and automated deployment scripts on victim servers; these scripts may call utilities like PsExec to deploy ransomware such as LockerGoga to as many machines as possible at the same time.
ACTION
Exfiltration Over Asymmetric Encrypted Non-C2 Protocol
TACTIC
[ENT] TA0010 Exfiltration
TECHNIQUE
[ENT] T1048.002 Exfiltration Over Asymmetric Encrypted Non-C2 Protocol
DESCRIPTION
FIN6 has exfiltrated this reconnaissance data to servers it controls using SSH. These actions are intended to enable FIN6's operational objective of monetizing compromised environments.
OR
MALWARE
LockerGoga
DESCRIPTION
FIN6 may stage ransomware and automated deployment scripts on victim servers; these scripts may call utilities like PsExec to deploy ransomware such as LockerGoga to as many machines as possible at the same time.
CONDITION
Exfiltrated Recon Data
True
False
CONDITION
Ransomware Distributed
True
False